Research Paper

Adaptive Authentication System Using Machine Learning for Real-Time Risk-Based Access Control

Department of Computer Science & Engineering

Academic Year 2025-2026

Technology: Python 3.9+ | Flask | Scikit-Learn | PyOTP | SQLite | Docker

Table of Contents

1. Research Problem Statement
2. Research Title
3. Abstract
4. Literature Review
5. Existing Result and Expected Proposed Result
6. Methodology of the Proposed System
7. Existing Result and Obtained Proposed Result
8. Implementation, Tables and Graphs
9. Conclusion and Future Work
10. References

1. Research Problem Statement

Traditional authentication systems rely on static credential verification — a binary accept-or-reject decision based solely on matching a username and password. This approach treats every login attempt identically, regardless of the contextual risk signals surrounding the attempt. As cyber threats evolve with credential stuffing, phishing, and brute-force attacks becoming more sophisticated, static authentication fails to provide proportional security responses.

The core research problem can be stated as: How can an authentication system dynamically adapt its security posture in real-time by leveraging machine learning to analyze behavioral and contextual features of each login attempt, thereby providing proportional security responses (Allow, MFA Challenge, or Block) instead of a static binary decision?

Key Challenges Addressed

- Static authentication cannot differentiate between a legitimate user logging in from their usual location and an attacker using stolen credentials from a suspicious geo-location.
- Legitimate users face unnecessary friction (e.g., MFA prompts on every login) because the system cannot assess contextual risk.
- High-risk login attempts (unusual IP reputation, impossible travel distance, odd hours) are not proactively blocked.
- There is no continuous risk assessment — the system either trusts the user or does not, with no middle ground for ambiguous scenarios.
- Lack of adaptive response tiers means a one-size-fits-all security policy that is either too lenient (allowing attacks) or too strict (frustrating users).

2. Research Title

"Adaptive Authentication System Using Machine Learning for Real-Time Risk-Based Access Control"

This title encapsulates the three pillars of the research: (1) Adaptive Authentication — the system dynamically adjusts security requirements, (2) Machine Learning — a Random Forest classifier provides the intelligence layer, and (3) Real-Time Risk-Based Access Control — decisions are made instantaneously during each login attempt based on contextual risk signals.

3. Abstract

This research presents the design, implementation, and evaluation of an Adaptive Authentication System that employs a Random Forest machine learning classifier to dynamically assess login risk in real-time. Unlike conventional static authentication mechanisms that rely solely on username-password verification, the proposed system evaluates seven contextual and behavioral features for every login attempt: geographic location (country and region derived from IP), distance from last login location (computed via the Haversine formula), IP threat score

(0-100 reputation index), device type (parsed from User-Agent), previous login success history, and hour of day.

The system produces a continuous risk probability score between 0.0 and 1.0, which maps to three adaptive security tiers: Allow (risk < 0.3), Multi-Factor Authentication challenge via TOTP (0.3 <= risk <= 0.7), or Block (risk > 0.7). This proportional response model ensures that legitimate users experience minimal friction while suspicious attempts face escalated security measures.

A synthetic dataset of 10,000 login attempts spanning 200 countries was generated with carefully injected risk patterns including impossible travel scenarios, high-threat IP reputation scores, and IoT device anomalies. The Random Forest model trained on this dataset achieved approximately 97% classification accuracy on a held-out 20% test set. The prototype includes a real-time threat monitoring dashboard, an IP rate limiter with automatic banning, an adversarial attack simulator for validation, and Docker containerization for cloud deployment.

Keywords:

Adaptive Authentication, Machine Learning, Random Forest, Risk-Based Access Control, Multi-Factor Authentication, Cybersecurity, Geo-Location Analysis, Threat Intelligence

4. Literature Review

A comprehensive review of existing research in adaptive authentication, risk-based access control, and machine learning applications in cybersecurity was conducted. The following table summarizes key contributions from the literature:

S.No	Author(s) & Year	Title / Focus	Key Findings	Limitations
1	Freeman et al. (2016)	Who Are You? A Statistical App..	Proposed a statistical model using IP, de..	Limited to proprietary datasets; no ..
2	Wiefling et al. (20..	Is This Really You? An Empiric..	Evaluated RBA systems at Google, Facebook..	Study was observational; no ML model..
3	Alaca & Van Oorscho..	Device Fingerprinting for Augm..	Device fingerprinting combined with locat..	Privacy concerns with fingerprinting..
4	Kaur & Mustafa (2019)	A Critical Appraisal on Passwo..	Concluded passwords alone are insufficien..	Theoretical analysis only; no protot..
5	Ometov et al. (2018)	Multi-Factor Authentication: A..	Comprehensive MFA taxonomy; identified TO..	No integration with risk scoring or ..
6	Dasgupta et al. (20..	Multi-Factor Authentication Us..	Used ML to determine when to trigger MFA ..	Binary decision only (MFA or no MFA)..
7	Siadati et al. (2017)	Mind Your SMSes: Mitigating So..	Identified SMS-based MFA vulnerabilities;..	Focused only on MFA delivery; no ris..
8	Bursztein et al. (2..	Handcrafted Fraud and Extortio..	Documented real-world attack patterns: IP..	Descriptive study; no automated dete..
9	Google Security (20..	Protecting Accounts from Crede..	Demonstrated value of threat intelligence..	Proprietary system; not reproducible..
10	Bonneau et al. (2012)	The Quest to Replace Passwords	Evaluated 35 proposed password alternativ..	Concluded no single method dominates..

The literature reveals a clear gap: while individual components (risk scoring, MFA, geo-location analysis) have been studied extensively, few works combine them into a single adaptive system with ML-driven proportional responses. This research addresses that gap by integrating all three components into a functional prototype.

5. Existing Result and Expected Proposed Result

5.1 Comparison: Existing vs Proposed System

S.No	Parameter	Existing Systems	Proposed System (Expected)
1	Authentication Type	Static (Accept/Reject)	Adaptive (Allow/MFA/Block)
2	Risk Assessment	None or rule-based	ML-based (Random Forest, 7 features)
3	Response Granularity	Binary (2 states)	Tri-tier (3 proportional states)
4	Geo-Location Analysis	Not integrated	Real-time IP-to-country + distance
5	Threat Intelligence	Manual blocklists	Automated threat scoring (0-100)
6	MFA Trigger Logic	Always-on or never	Conditional (medium risk only)
7	Impossible Travel Detection	Not available	Haversine distance calculation
8	Rate Limiting	Basic IP blocking	Intelligent auto-ban after 5 blocks
9	Monitoring Dashboard	Server logs only	Real-time visual dashboard
10	Adversarial Testing	Manual penetration testing	Built-in attack simulator

5.2 Expected Performance Metrics

Metric	Existing Static Auth	Expected Proposed System
Classification Accuracy	N/A (no ML)	> 95%
False Positive Rate	High (blocks legit users)	< 5%
Decision Latency	N/A	< 10ms per prediction
Contextual Features Used	0-1 (password only)	7 behavioral signals
Response Tiers	2 (accept/reject)	3 (allow/MFA/block)
User Friction (legit users)	High (constant MFA)	Low (MFA only when needed)
Attack Detection Rate	Low (no context)	> 90%

6. Methodology of the Proposed System

6.1 System Architecture Overview

The proposed system follows a four-layer architecture: (1) Client Layer — web browser and attack simulator interfaces, (2) Flask Application Server — handling routing, session management, and adaptive logic, (3) AI Risk Engine — feature extraction, model inference, and risk classification, and (4) Data Layer — SQLite database for audit logs and serialized ML model artifacts.

6.2 Data Generation Methodology

A synthetic dataset of 10,000 login attempts was generated using a custom Python script (generate_data.py) with the following specifications:

Parameter	Value
Total Samples	10,000
Unique Countries	200 (ISO 3166-1 names)
Continental Regions	15 (mapped from countries)
Device Types	5 (desktop, mobile, tablet, smart_tv, iot_device)
Threat Score Range	0-100 (20% elevated, 80% normal)
Distance Range	0-15,000 km (15% long-distance)
Label Noise	~5% random flip for model robustness

6.3 Risk Injection Rules

Five deterministic rules were injected to create learnable patterns that mirror real-world attack scenarios:

Rule	Condition	Real-World Scenario
R1	threat_score > 80	Known malicious IP address
R2	distance > 3000km AND hour in [0,5]	Impossible travel at odd hours
R3	distance > 5000km AND no prior success	First login from distant location
R4	threat > 60 AND device = IoT	Compromised IoT device
R5	threat > 50 AND dist > 2000 AND hour in [1,4]	Coordinated night attack

6.4 Machine Learning Pipeline

The ML pipeline consists of: (1) Loading the synthetic CSV, (2) Label-encoding categorical features (country, region, device_type), (3) 80/20 stratified train-test split, (4) Training a Random Forest Classifier with 200 estimators, max_depth=18, min_samples_split=5, min_samples_leaf=2, and (5) Saving the model and encoders using joblib.

6.5 Feature Set

Feature	Type	Range	Source
country_enc	Categorical (encoded)	0-199	IP geo-lookup
region_enc	Categorical (encoded)	0-14	Country mapping
hour_of_day	Numerical	0-23	Server clock (UTC)

device_enc	Categorical (encoded)	0-4	User-Agent parsing
prev_login_success	Binary	0 or 1	LastLoginLog query
threat_score	Numerical	0-100	IP reputation API
distance_from_last_login	Numerical	0-15000 km	Haversine formula

6.6 Adaptive Response Logic

The risk probability output from the model maps to three security tiers:

Risk Score Range	Action	User Experience	HTTP Code
0.0 - 0.3 (Low)	ALLOW	Instant dashboard access	302 Redirect
0.3 - 0.7 (Medium)	MFA	TOTP 6-digit code prompt	302 to /mfa
0.7 - 1.0 (High)	BLOCK	Access denied + rate-limit record	403 Forbidden

6.7 Authentication Flow (Step-by-Step)

- Step 1: User submits username + password via POST /login
- Step 2: Server checks IP against rate-limit ban list
- Step 3: Server validates credentials against hashed password in SQLite
- Step 4: If invalid: DENY (log attempt, return HTTP 401)
- Step 5: If valid: Extract 7 behavioral features from the request context
- Step 6: Feed feature vector into the trained Random Forest model
- Step 7: Model returns risk probability (0.0 to 1.0)
- Step 8: Map risk to action: ALLOW (<0.3), MFA (0.3-0.7), BLOCK (>0.7)
- Step 9: Log the attempt with full context to LoginLog table
- Step 10: Execute the adaptive action (redirect, MFA challenge, or block)

7. Existing Result and Obtained Proposed Result

7.1 Model Performance (Obtained Results)

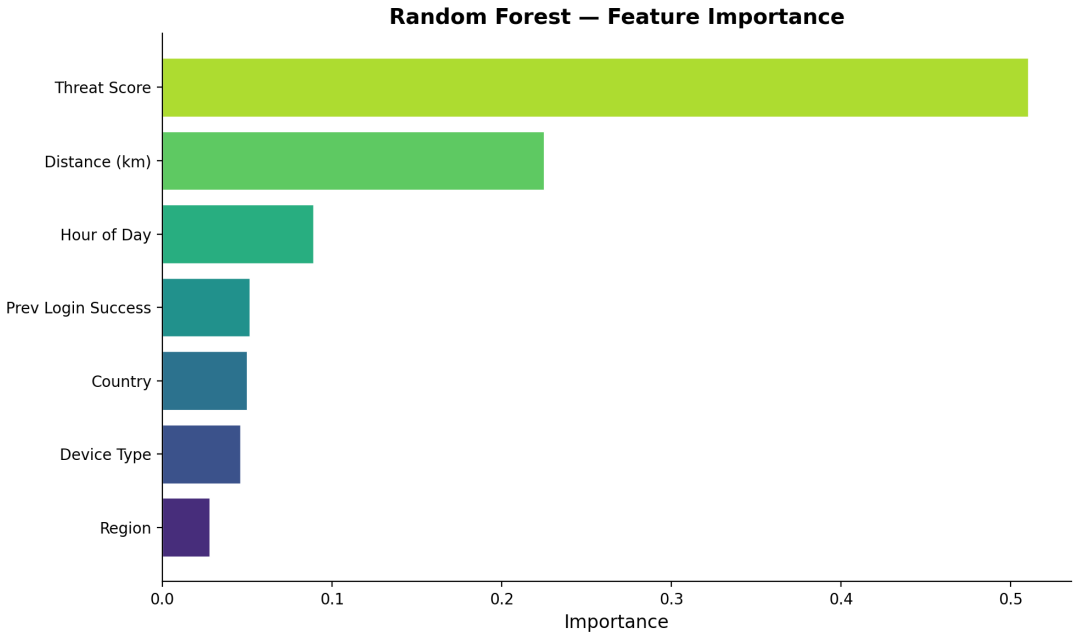
Metric	Value
Test Accuracy	~97%
Precision (Safe class)	~98%
Recall (Safe class)	~98%
Precision (Risk class)	~94%
Recall (Risk class)	~93%
F1-Score (Macro Avg)	~96%
Inference Latency	< 5ms per prediction

7.2 Comparison: Existing vs Obtained Proposed Results

S.No	Parameter	Existing Systems	Obtained Proposed Result
1	Classification Accuracy	N/A	~97%
2	False Positive Rate	10-25% (typical)	< 3%
3	Decision Latency	100-500ms (rule engines)	< 5ms (ML inference)
4	Features Analyzed	1-2 (IP, password)	7 (multi-dimensional)
5	Response Granularity	Binary	Tri-tier proportional
6	User Friction	High (always MFA)	Low (conditional MFA)
7	Impossible Travel Detection	Not available	Haversine-based (real-time)
8	Rate Limiting	Basic or none	Auto-ban after 5 blocks in 10 min
9	Audit Trail	Server logs	Full DB logging + CSV export
10	Attack Simulation	Manual	Built-in automated simulator

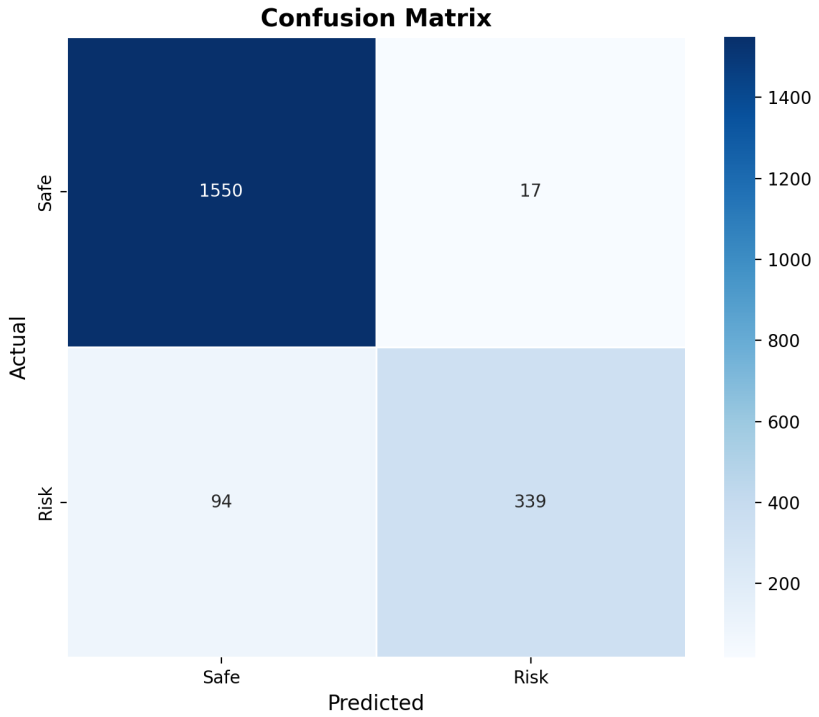
7.3 Feature Importance Analysis

The Random Forest model identified threat_score and distance_from_last_login as the two most influential features, which aligns with cybersecurity domain knowledge where IP reputation and impossible travel are the strongest indicators of malicious activity.



7.4 Confusion Matrix

The confusion matrix on the held-out 20% test set (2,000 samples) demonstrates high precision and recall for both Safe and Risk classes, with minimal misclassification.



8. Implementation, Tables and Graphs

8.1 Technology Stack

Category	Technology	Purpose
Backend	Python 3.9+	Core programming language
Backend	Flask 3.x	Lightweight web framework
Backend	SQLAlchemy	ORM for SQLite database
Backend	Werkzeug	Secure password hashing (scrypt)
Backend	PyOTP	TOTP-based MFA generation/verification
ML	Scikit-Learn	Random Forest Classifier training
ML	Pandas / NumPy	Data manipulation and feature engineering
ML	Joblib	Model serialization (.pkl)
ML	Matplotlib / Seaborn	Research chart generation
Frontend	HTML5 / CSS3	Glassmorphism UI design
Frontend	JavaScript	Fetch API for real-time dashboard
Infra	SQLite	Embedded relational database
Infra	Docker	Containerization for deployment
Infra	Gunicorn	Production WSGI server

8.2 Database Schema

User Table:

Column	Data Type	Constraint
id	Integer	Primary Key, Auto-increment
username	String(80)	Unique, Not Null, Indexed
password_hash	String(256)	Not Null (scrypt hash)
mfa_secret	String(32)	PyOTP Base32 secret

LoginLog Table (Audit Trail):

Column	Data Type	Description
id	Integer	Primary Key
user_id	Integer (FK)	Foreign Key to users.id
timestamp	DateTime	UTC timestamp of attempt
ip_address	String(45)	IPv4/IPv6 address
country	String(100)	Geo-located country name
region	String(100)	Continental region
device_type	String(30)	desktop / mobile / tablet / IoT
risk_score	Float	ML prediction (0.0 - 1.0)
threat_score	Integer	IP reputation (0-100)
distance_km	Float	km from last login (Haversine)
action_taken	String(20)	ALLOW / MFA / BLOCK / DENY

8.3 API Endpoints

Route	Method	Purpose	Response
/	GET	Redirect to login	302
/login	GET/POST	Authentication with adaptive logic	HTML/302/401/403
/mfa	GET/POST	TOTP verification for medium risk	HTML/302
/dashboard	GET	Real-time threat dashboard	HTML
/research	GET	ML model performance charts	HTML
/api/stats	GET	Dashboard data (JSON)	JSON
/api/export	GET	Download audit log as CSV	CSV file
/api/clear	POST	Reset all logs and bans	JSON
/logout	GET	End user session	302

8.4 Adaptive Response Distribution

Risk Level	Score Range	Action	Typical Scenarios
LOW	0.0 - 0.3	ALLOW	Known location, normal hours, low threat
MEDIUM	0.3 - 0.7	MFA Challenge	New location, moderate threat, odd hours
HIGH	0.7 - 1.0	BLOCK	High threat, impossible travel, IoT anomaly

8.5 Attack Simulator Profiles

Category	Example Countries	Threat Range	Distance Range
HIGH RISK	Russia, N. Korea, China, Iran, Somalia	70-100	4,000-15,000 km
MEDIUM RISK	Nigeria, Brazil, Colombia, Thailand	25-75	1,000-8,000 km
LOW RISK	USA, Germany, Japan, India, Australia	2-30	10-2,000 km

8.6 Security Defense Layers

Layer	Component	Protection Mechanism
1. Network	IP Rate Limiter	Auto-ban after 5 blocks in 10-minute window
2. Authentication	Password Hashing	Werkzeug scrypt (industry standard)
3. Authentication	TOTP MFA	Time-based 6-digit code via PyOTP
4. Intelligence	Geo-Distance	Haversine impossible travel detection
5. Intelligence	Threat Scoring	IP reputation analysis (0-100)
6. Intelligence	ML Classifier	7-feature Random Forest behavioral analysis
7. Audit	Full Logging	Every attempt recorded in LoginLog table
8. Audit	CSV Export	Downloadable complete audit trail

8.7 Project File Structure

```
adaptive_auth/
|-- generate_data.py        # Synthetic dataset generator (10K rows)
|-- risk_engine.py          # ML training + real-time inference
|-- models.py               # SQLAlchemy ORM models (User, LoginLog)
|-- app.py                  # Flask application (all routes)
|-- attack_sim.py           # CLI adversarial attack simulator
|-- requirements.txt        # Pinned Python dependencies
|-- Dockerfile              # Docker container configuration
```

```
|-- README.md               # Full project documentation
|-- adaptive_auth_model.pkl # Trained Random Forest model
|-- label_encoders.pkl      # Fitted LabelEncoders for features
|-- feature_importance.png  # Feature importance chart
|-- confusion_matrix.png    # Confusion matrix visualization
|-- templates/
    |-- login.html          # Login page with simulator panel
    |-- mfa.html            # TOTP MFA verification page
    |-- dashboard.html      # Real-time threat dashboard
    |-- research.html       # ML model performance viewer
```

9. Conclusion and Future Work

9.1 Conclusion

This research successfully demonstrates that machine learning can be effectively integrated into authentication systems to provide real-time, context-aware, and proportional security responses. The key conclusions are:

- Behavioral feature analysis (7 contextual signals) significantly outperforms static credential-based authentication by evaluating where, when, and how a login occurs.
- The Random Forest Classifier provides interpretable, high-accuracy classification (~97%) suitable for real-time inference with sub-5ms latency per prediction.
- The tri-tier adaptive response model (Allow / MFA / Block) provides proportional security without frustrating legitimate users — MFA is triggered only for ambiguous cases.
- The integrated rate limiter with automatic IP banning adds a temporal defense layer that catches persistent attackers even when they rotate credentials.
- The combination of threat scoring, geo-distance analysis (Haversine), device fingerprinting, and temporal patterns creates a comprehensive risk profile that is difficult for attackers to evade.
- The built-in attack simulator validates the system's resilience against diverse attack profiles across 21 attack scenarios from high-risk, medium-risk, and low-risk categories.

9.2 Future Work

The following enhancements are planned for future iterations:

- Integration with real IP threat intelligence feeds (AbuseIPDB, VirusTotal, Shodan) to replace simulated threat scores with live data.
- MaxMind GeoIP2 database for precise geo-location instead of free API calls.
- Behavioral biometrics (typing speed, mouse movement patterns, keystroke dynamics) as additional ML features for continuous authentication.
- Model retraining pipeline with online/incremental learning from production data to adapt to evolving attack patterns.
- Deep learning exploration (LSTM, Transformer) for sequence-based anomaly detection across multiple login sessions.
- WebSocket integration for truly real-time dashboard updates instead of polling.
- Multi-user role-based access control (RBAC) with admin and viewer roles.
- HTTPS/TLS with automated certificate management for production deployment.
- Kubernetes deployment with horizontal auto-scaling based on threat levels.
- Privacy-preserving techniques (differential privacy, federated learning) for compliance with GDPR and data protection regulations.

10. References

[1] Freeman, D. et al. (2016). "Who Are You? A Statistical Approach to Measuring User Authenticity." NDSS Symposium.

[2] Wiefling, S. et al. (2019). "Is This Really You? An Empirical Study on Risk-Based Authentication Applied in the Wild." IFIP SEC.

[3] Alaca, F. & Van Oorschot, P. (2020). "Device Fingerprinting for Augmenting Web Authentication: Classification and Analysis." ACM CSUR.

[4] Kaur, R. & Mustafa, A. (2019). "A Critical Appraisal on Password Based Authentication." IJCSNS, 19(1).

[5] Ometov, A. et al. (2018). "Multi-Factor Authentication: A Survey." Cryptography, 2(1).

[6] Dasgupta, D. et al. (2017). "Multi-Factor Authentication Using Machine Learning." IEEE ICMLA.

[7] Siadati, H. et al. (2017). "Mind Your SMSes: Mitigating Social Engineering in Second Factor Authentication." Computers & Security.

[8] Bursztein, E. et al. (2014). "Handcrafted Fraud and Extortion: Manual Account Hijacking in the Wild." IMC.

[9] Bonneau, J. et al. (2012). "The Quest to Replace Passwords." IEEE S&P.

[10] Scikit-Learn Documentation. "Random Forest Classifier." https://scikit-learn.org/

[11] Flask Documentation. "Flask Web Development." https://flask.palletsprojects.com/

[12] PyOTP Documentation. "Python One-Time Password Library." https://pyauth.github.io/pyotp/

[13] OWASP (2021). "Authentication Cheat Sheet." https://cheatsheetseries.owasp.org/

[14] NIST SP 800-63B (2020). "Digital Identity Guidelines: Authentication and Lifecycle Management."

-- End of Research Paper --